

1. Security Assessment Using Nmap — 192.168.1.20

Aim

To perform a security assessment of the server 192.168.1.20 using Nmap, identify open ports and running services, analyze their purpose, and recommend measures to reduce the system's attack surface.

Command

First check whether the host is active:

```
nmap -sn 192.168.1.20
```

Perform a basic port scan:

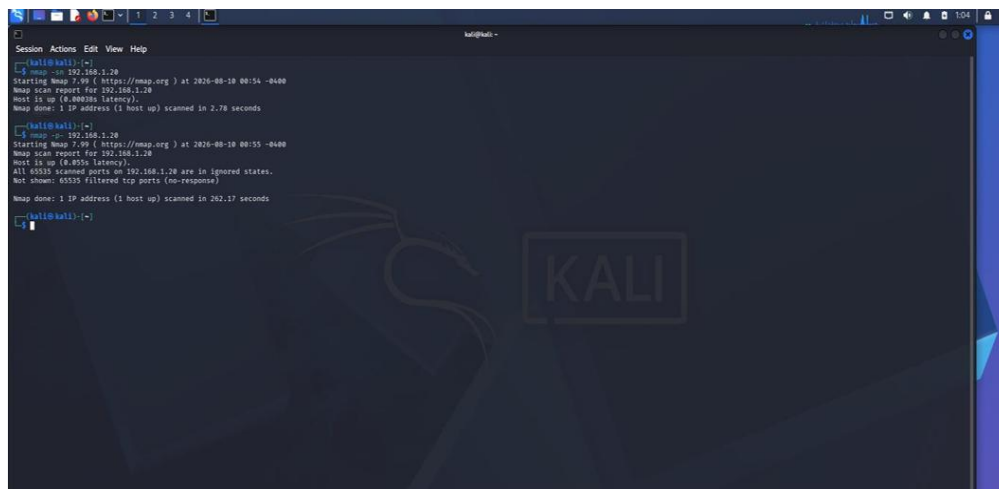
```
nmap 192.168.1.20
```

Scan all TCP ports:

```
nmap -p- 192.168.1.20
```

Detect services and versions:

```
nmap -sV 192.168.1.20
```

A screenshot of a Kali Linux terminal window. The terminal shows the execution of Nmap commands and their output. The first command is 'nmap -sn 192.168.1.20', which returns 'Host is up (4.88ms latency)' and 'Nmap done: 1 IP address (1 host up) scanned in 2.78 seconds'. The second command is 'nmap 192.168.1.20', which returns 'Starting Nmap 7.90 (https://nmap.org) at 2026-08-10 00:54 -0400', 'Nmap scan report for 192.168.1.20', 'Host is up (4.855s latency)', 'All 65535 scanned ports on 192.168.1.20 are in ignored states.', 'Not shown: 65535 filtered tcp ports (no response)', and 'Nmap done: 1 IP address (1 host up) scanned in 261.17 seconds'. The terminal background features a Kali Linux logo and the word 'KALI'.

Perform OS detection:

```
sudo nmap -O 192.168.1.20
```

Comprehensive scan:

```
sudo nmap -p- -sC -sV -O 192.168.1.20
```

```
Session Actions Edit View Help
kali@kali:~$ nmap -i 192.168.1.20
Starting Nmap 7.99 ( https://nmap.org ) at 2024-09-18 01:11 -0400
Nmap scan report for 192.168.1.20
Host is up (0.400000s latency).
All 1000 scanned ports on 192.168.1.20 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.79 seconds

kali@kali:~$ sudo nmap -i 192.168.1.20 -p 1-65535
Starting Nmap 7.99 ( https://nmap.org ) at 2024-09-18 01:13 -0400
Nmap scan report for 192.168.1.20
Host is up (0.400000s latency).
Not shown: 95 open/filtered up ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
3306/tcp  open  mysql
Other     filtered
Nmap done: 1 IP address (1 host up) scanned in 37.14 seconds

kali@kali:~$ sudo nmap -i 192.168.1.20 -p 1-65535 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2024-09-18 01:15 -0400
Status: 01:15:28 elapsed; 8 hosts completed (1 up); 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.00s done; 0% (0/10) remaining

kali@kali:~$ nmap -i 192.168.1.20
Starting Nmap 7.99 ( https://nmap.org ) at 2024-09-18 01:17 -0400
Nmap scan report for 192.168.1.20
Host is up (0.400000s latency).
All 1000 scanned ports on 192.168.1.20 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.57 seconds

kali@kali:~$
```

Save the result:

```
sudo nmap -p- -sC -sV -O 192.168.1.20 -oN nmap_192.168.1.20.txt
```

Result

Record the ports obtained from your Nmap output:

Port	Service	Purpose	Risk
22	SSH	Secure remote administration	Medium
80	HTTP	Web service	Medium/High
443	HTTPS	Secure web service	Medium
3306	MySQL	Database service	High if externally exposed
Other	As detected	Analyze according to service	Depends

Do not report ports that are not present in your actual scan.

Analysis

SSH — Port 22

SSH provides secure remote administration.

Security concerns:

- Password-based attacks
- Weak credentials
- Outdated SSH software
- Excessive administrative privileges

Recommendation: Restrict SSH to authorized management hosts and use strong authentication.

HTTP — Port 80

HTTP provides web content.

Potential concerns include:

- Web application vulnerabilities
- Information disclosure
- Misconfigured directories
- Outdated web-server software

Recommendation: Use HTTPS and disable HTTP if it is not required.

HTTPS — Port 443

HTTPS provides encrypted web communication.

Recommendation: Keep TLS configuration and web-server software updated.

Database Services

If a database port such as 3306 is exposed, it should normally be restricted to application/database networks rather than being accessible from arbitrary hosts.

Attack Surface Reduction

1. Disable unnecessary services.
2. Close unused ports using firewall rules.
3. Keep services updated.
4. Restrict SSH access.
5. Use strong authentication.
6. Avoid exposing databases directly.
7. Use HTTPS for web applications.
8. Monitor logs and authentication attempts.
9. Apply least-privilege access.
10. Regularly perform vulnerability assessments.

Conclusion

Nmap successfully identifies the network services exposed by 192.168.1.20. Only services required for legitimate business operations should remain accessible.

2. Web Server Assessment Using Nikto — 192.168.1.30

Aim

To assess the web server running on 192.168.1.30 using Nikto and identify potentially outdated software, insecure configurations, exposed files, and directories.

Basic Command

```
nikto -h http://192.168.1.30
```

If HTTPS is being used:

```
nikto -h https://192.168.1.30
```

Save results:

```
nikto -h http://192.168.1.30 -o nikto_192.168.1.30.txt
```

Result

Record the findings reported by Nikto.

Finding	Description	Risk
Server version disclosure	Web server reveals software/version	Medium
Outdated component	Old software detected	High
Directory listing	Directory contents visible	Medium/High
Backup file	Backup/configuration file exposed	High
Missing security header	Security header absent	Low/Medium
Administrative page	Management interface exposed	High

Analysis

SSH — Port 22

SSH provides secure remote administration.

Security concerns:

- Password-based attacks
- Weak credentials
- Outdated SSH software

- Excessive administrative privileges

Recommendation: Restrict SSH to authorized management hosts and use strong authentication.

HTTP — Port 80

HTTP provides web content.

Potential concerns include:

- Web application vulnerabilities
- Information disclosure
- Misconfigured directories
- Outdated web-server software

Recommendation: Use HTTPS and disable HTTP if it is not required.

HTTPS — Port 443

HTTPS provides encrypted web communication.

Recommendation: Keep TLS configuration and web-server software updated.

Database Services

If a database port such as 3306 is exposed, it should normally be restricted to application/database networks rather than being accessible from arbitrary hosts.

Attack Surface Reduction

1. Disable unnecessary services.
2. Close unused ports using firewall rules.
3. Keep services updated.
4. Restrict SSH access.
5. Use strong authentication.
6. Avoid exposing databases directly.
7. Use HTTPS for web applications.
8. Monitor logs and authentication attempts.
9. Apply least-privilege access.
10. Regularly perform vulnerability assessments.

Conclusion

Nmap successfully identifies the network services exposed by 192.168.1.20. Only services required for legitimate business operations should remain accessible.

2. Web Server Assessment Using Nikto — 192.168.1.30

Aim

To assess the web server running on 192.168.1.30 using Nikto and identify potentially outdated software, insecure configurations, exposed files, and directories.

Basic Command

```
nikto -h http://192.168.1.30
```

If HTTPS is being used:

```
nikto -h https://192.168.1.30
```

Save results:

```
nikto -h http://192.168.1.30 -o nikto_192.168.1.30.txt
```

Result

Record the findings reported by Nikto.

Finding	Description	Risk
Server version disclosure	Web server reveals software/version	Medium
Outdated component	Old software detected	High
Directory listing	Directory contents visible	Medium/High
Backup file	Backup/configuration file exposed	High
Missing security header	Security header absent	Low/Medium
Administrative page	Management interface exposed	High

Again, include only findings that Nikto actually reports in your scan.

Common Security Issues

1. Server Version Disclosure

If the server reveals its software/version, attackers can research vulnerabilities associated with that version.

Mitigation: Minimize unnecessary version disclosure and keep the software patched.

2. Directory Listing

Directory indexing may reveal:

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.56.103 netmask 255.255.255.0 up
msfadmin@metasploitable:~$ ifconfig eth0
Link encap:Ethernet HWaddr 08:00:27:73:fb:10
  inet addr:192.168.56.103 Bcast:192.168.56.255 Mask:255.255.255.0
  inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
  UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
  RX packets:519 errors:0 dropped:0 overruns:0 frame:0
  TX packets:77 errors:0 dropped:0 overruns:0 carrier:0
  collisions:0 txqueuelen:1000
  RX bytes:34902 (34.0 KB)  TX bytes:10419 (10.1 KB)
  Base address:0xd020 Memory:f0200000-f0220000

lo
Link encap:Local Loopback
  inet addr:127.0.0.1 Mask:255.0.0.0
  inet6 addr: ::1/128 Scope:Host
  UP LOOPBACK RUNNING  MTU:65536 Metric:1
  RX packets:118 errors:0 dropped:0 overruns:0 frame:0
  TX packets:118 errors:0 dropped:0 overruns:0 carrier:0
  collisions:0 txqueuelen:0
  RX bytes:31841 (31.0 KB)  TX bytes:31841 (31.0 KB)

msfadmin@metasploitable:~$ _
```

[illegible]

- Application files
- Backups
- Configuration files
- Logs
- Source code

Mitigation: Disable directory listing unless specifically required.

3. Backup Files

Files such as:

backup.zip

database.sql

config.bak

index.old

may expose sensitive information.

Mitigation: Remove unnecessary backup files from the web root.

1. Update web-server software.
2. Remove unnecessary files.
3. Disable directory listing.
4. Remove backup files from the document root.
5. Restrict administrative interfaces.
6. Configure appropriate security headers.
7. Use HTTPS.

8. Apply secure file permissions.
9. Monitor web-server logs.
10. Perform regular web-security assessments.

Conclusion

Nikto provides useful information about common web-server weaknesses and configuration problems. Its findings should be validated before treating them as confirmed vulnerabilities.

3. Service Banner Investigation Using Netcat — 192.168.1.40

Aim

To use Netcat to connect to open ports on 192.168.1.40, collect service banners, and analyze how banner information can assist reconnaissance.

Step 1: Identify Open Ports

First use Nmap to determine which ports are open:

nmap 192.168.1.40

Suppose the scan identifies:

22

80

25

Use the actual ports from your scan.

```

Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(64) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=27.9 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=7.04 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=51.4 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=9.63 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3014ms
rtt min/avg/max/mdev = 7.038/23.993/51.377/17.743 ms

kali@kali:~$ nc -v 192.168.56.102 1-1000
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 514 (shell) open
(UNKNOWN) [192.168.56.102] 513 (login) open
(UNKNOWN) [192.168.56.102] 512 (exec) open
(UNKNOWN) [192.168.56.102] 445 (microsoft-ds) open
(UNKNOWN) [192.168.56.102] 139 (netbios-ssn) open
(UNKNOWN) [192.168.56.102] 111 (sunrpc) open
(UNKNOWN) [192.168.56.102] 80 (http) open
(UNKNOWN) [192.168.56.102] 53 (domain) open
(UNKNOWN) [192.168.56.102] 25 (smtp) open
(UNKNOWN) [192.168.56.102] 23 (telnet) open
(UNKNOWN) [192.168.56.102] 22 (ssh) open
(UNKNOWN) [192.168.56.102] 21 (ftp) open

kali@kali:~$ nc -v 192.168.56.102 21
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 21 (ftp) open
228 (vsFTPd 2.3.4)

kali@kali:~$ nc -v 192.168.56.102 22
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

kali@kali:~$ nc -v 192.168.56.102 80
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 80 (http) open
GET / HTTP/1.0

HTTP/1.1 200 OK
Date: Tue, 11 Aug 2020 04:59:44 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2

```

```

Session / Terminal Emulator
Use the command line
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

kali@kali:~$ nc -v 192.168.56.102 80
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 80 (http) open
GET / HTTP/1.0

HTTP/1.1 200 OK
Date: Tue, 11 Aug 2020 04:59:44 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>

metasploitable2

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

</pre>
<ul>
<li><a href="/twiki/">Twiki</a></li>
<li><a href="/phpmyadmin/">phpmyadmin</a></li>
<li><a href="/mutillidae/">Mutillidae</a></li>
<li><a href="/dvs/">DVS</a></li>
<li><a href="/dav/">WebDAV</a></li>
</ul>
</body>
</html>

kali@kali:~$ nc -v 192.168.56.102 25
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 25 (smtp) open
228 metasploitable.localdomain ESMTD Postfix (Ubuntu)

```

Step 2: Connect Using Netcat

For SSH:

nc -v 192.168.1.40 22

For HTTP:

nc -v 192.168.1.40 80

For SMTP:

nc -v 192.168.1.40 25

For HTTP, you can send a basic request:

GET / HTTP/1.1

Host: 192.168.1.40

Result

Record the banners obtained.

Port	Service	Banner Information	Security Significance
22	SSH	Actual banner	Reveals SSH implementation/version
80	HTTP	Server header	Reveals web-server technology
25	SMTP	Mail-server banner	Reveals mail software
Other	Actual service	Actual banner	Analyze

Example

A banner might look similar to:

SSH-2.0-OpenSSH_...

This reveals the SSH implementation and potentially its version.

An HTTP response might contain:

Server: ...

This can reveal information about the web-server software.

Use your actual output in the final report.

How Attackers Use Banner Information

Banner information can help an attacker determine:

1. Technology Identification

The attacker can identify the software running on a port.

2. Version Identification

If a version is disclosed, it can be compared with publicly known vulnerabilities.

3. Attack Prioritization

Attackers can prioritize services that appear outdated or vulnerable.

4. Operating-System Inference

Certain service banners can provide clues about the underlying platform.

5. Reconnaissance

The information helps build a technology profile:

IP Address



Open Port



Service



Version



Potential Vulnerabilities

Security Recommendations

1. Minimize unnecessary banner disclosure.
2. Keep services patched.
3. Disable unnecessary services.
4. Use firewalls to restrict access.
5. Monitor repeated connection attempts.
6. Avoid exposing internal services unnecessarily.

Conclusion

Netcat demonstrates how simple connections can reveal service information. Banner information is valuable during reconnaissance because it allows an attacker to understand the technologies exposed by a target.

Aim

To determine whether remote administration services are accessible on 192.168.1.50 using Telnet and identify associated security concerns.

Use Telnet only against your authorized laboratory host. Do not attempt authentication using credentials that you are not authorized to use.

Step 1: Identify Open Ports

```
nmap 192.168.1.50
```

Look especially for:

22

23

3389

5900

Step 2: Connect to Telnet

If port 23 is open:

```
telnet 192.168.1.50 23
```

If Telnet is not installed on Windows, you may need to enable the Telnet Client or use a Linux lab machine.

Step 3: Test Other Authorized Services

For SSH:

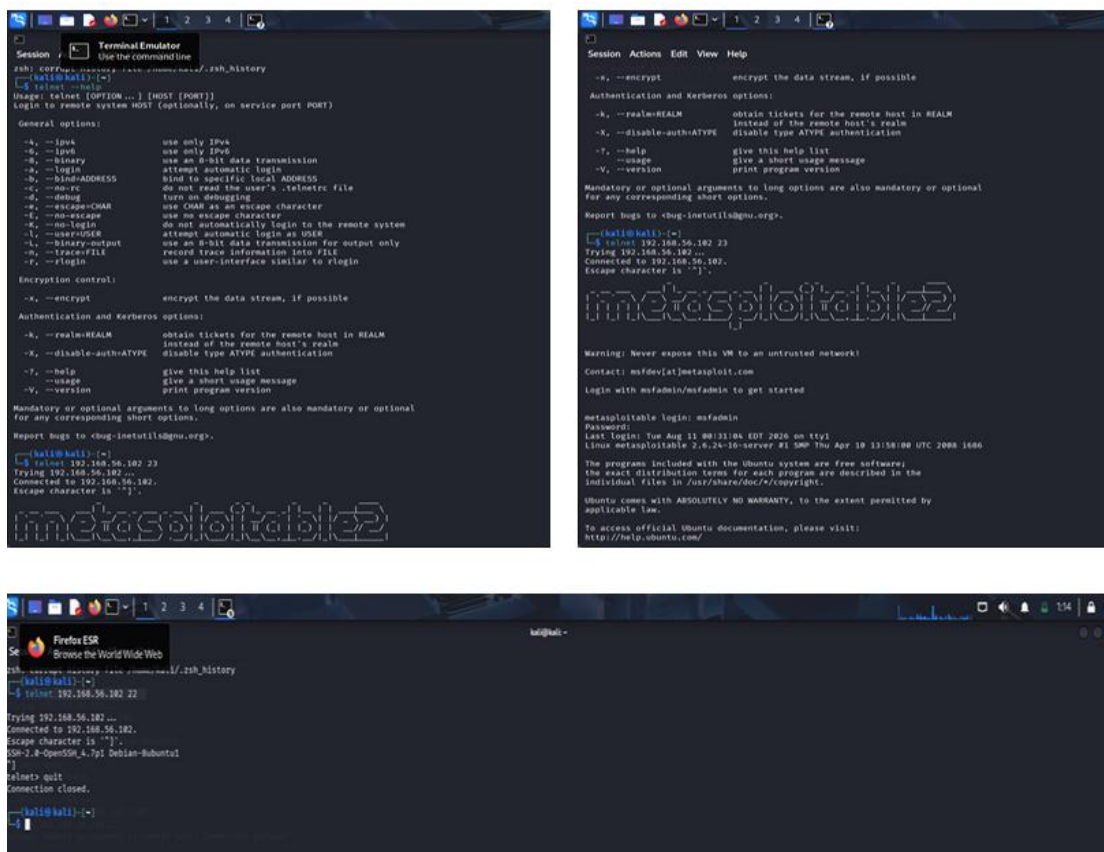
```
telnet 192.168.1.50 22
```

This can sometimes display an SSH banner.

For HTTP:

```
telnet 192.168.1.50 80
```

The purpose here is to determine whether the port responds, not to bypass authentication.



Analysis

Telnet — Port 23

Telnet is an old remote-administration protocol.

Its major weakness is the lack of modern encryption for the session.

Potential consequences include exposure of:

- Usernames
- Passwords
- Commands
- Administrative information

Risk

High, particularly when Telnet is exposed beyond a trusted management network.

SSH — Port 22

SSH is a more secure alternative to Telnet because it provides encrypted communication.

Recommendation

Replace:

Telnet → SSH

Use:

- Strong authentication
- SSH keys
- MFA where supported
- Firewall restrictions
- Current SSH software

RDP — Port 3389

If the system is a Windows server and RDP is exposed, restrict it to authorized management networks or VPN access.

Security Concerns

Service	Concern	Recommendation
Telnet	Unencrypted remote administration	Disable
SSH	Authentication attacks	Restrict and harden
RDP	Remote-access exposure	Restrict to trusted network/VPN
VNC	Remote desktop exposure	Restrict and encrypt

Hardening

1. Disable Telnet.
2. Use SSH instead.
3. Restrict management ports using firewall rules.
4. Use strong authentication.
5. Enable MFA where possible.
6. Patch remote-management software.
7. Monitor authentication logs.
8. Limit administrator accounts.

Conclusion

Telnet should generally not be used for secure remote administration. SSH or another properly secured management mechanism should be preferred.

5. Network Host Discovery Using Netdiscover — 192.168.1.1–50

Aim

To discover active hosts on the authorized local network segment and analyze how host-discovery information can support subsequent security assessment.

Important Note

Netdiscover is primarily useful on a **local Layer-2/Ethernet network** because it uses ARP-based discovery.

Command

A typical Netdiscover scan can be performed against the local subnet:

```
sudo netdiscover -r 192.168.1.0/24
```

If you specifically need to examine addresses 192.168.1.1–50, use the network scan and filter the output for that range.

On a lab network, you can also use:

```
sudo netdiscover -i eth0 -r 192.168.1.0/24
```

Replace eth0 with your actual network interface.

To identify your interface:

```
ip addr
```

Result

Netdiscover may produce output similar to:

IP Address	MAC Address	Count	Len	MAC Vendor
192.168.1.1	XX:XX:XX:XX:XX:01	1	60	Vendor
192.168.1.10	XX:XX:XX:XX:XX:10	1	60	Vendor
192.168.1.20	XX:XX:XX:XX:XX:20	1	60	Vendor
192.168.1.30	XX:XX:XX:XX:XX:30	1	60	Vendor

These are only examples. Use the actual output from your laboratory network.

Host Discovery Table

Prepare your final result like this:

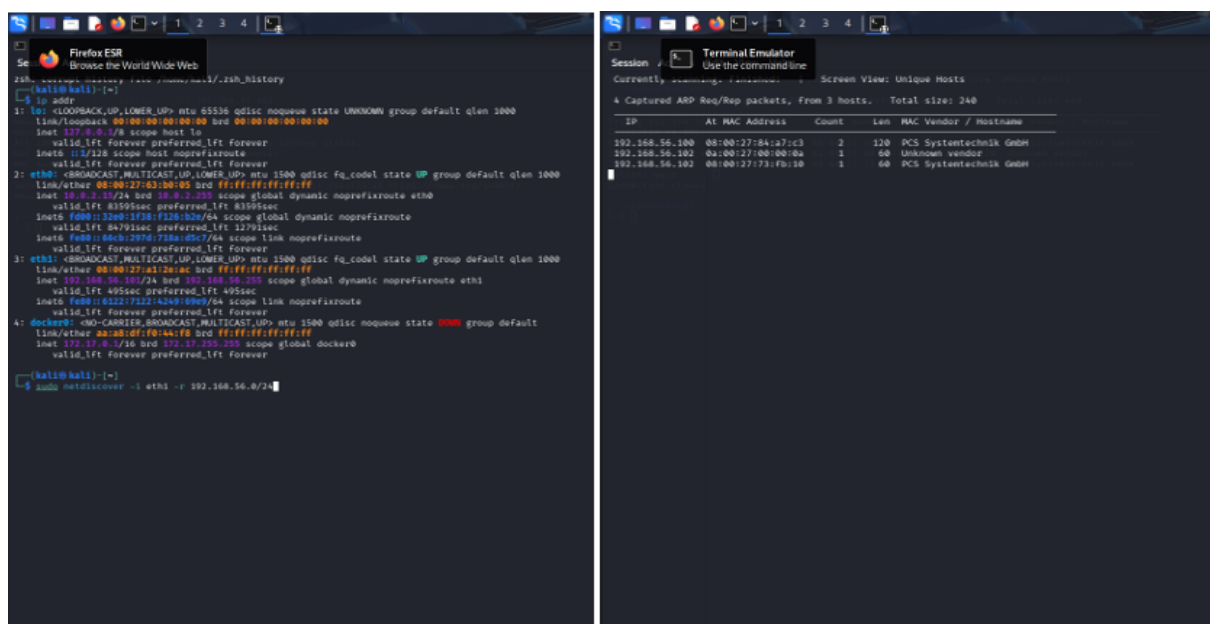
IP Address	MAC Address	Vendor	Status
192.168.1.1	Actual result	Actual vendor	Active
192.168.1.x	Actual result	Actual vendor	Active
192.168.1.x	Actual result	Actual vendor	Active

Analysis

Netdiscover can provide:

- IP addresses
- MAC addresses
- Hardware/vendor information
- Number of responding hosts

This allows an administrator or authorized penetration tester to create an initial network inventory.

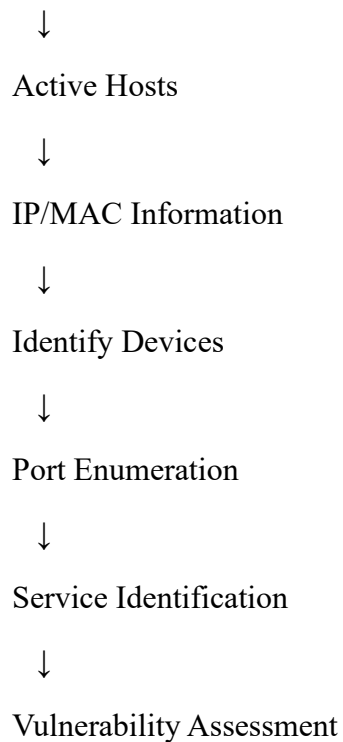


How Attackers Could Use Host Discovery

An attacker who gains access to a local network could use host-discovery information to identify potential targets.

The reconnaissance process could be:

Network



For example, after discovering a host at 192.168.1.20, an authorized tester might perform:

```
nmap 192.168.1.20
```

to determine what services are exposed.

Security Risks

Host discovery itself does not exploit a system, but it provides valuable network intelligence.

An attacker could potentially use the information to:

1. Identify servers.
2. Identify gateways.
3. Identify workstations.
4. Determine device vendors.
5. Select targets for further enumeration.
6. Map the internal network.

Security Recommendations

1. Network Segmentation

Separate:

Servers

Workstations

Management

IoT

Guest devices

into appropriate network segments.

2. Access Control

Use firewalls and network access controls to restrict unnecessary communication between hosts.

3. Monitor ARP Activity

Unexpected ARP scanning or unusual network-discovery activity can be investigated.

4. Maintain Asset Inventory

Organizations should know:

- Which devices are connected
- Their purpose
- Their owner
- Required services

5. Remove Unauthorized Devices

Unknown devices discovered on the network should be investigated.

Final Summary

Question	Tool	Main Purpose
1	Nmap	Port and service enumeration
2	Nikto	Web-server security assessment
3	Netcat	Service/banner investigation
4	Telnet	Remote-service accessibility testing
5	Netdiscover	Local-network host discovery

Overall Security Assessment Methodology

Host Discovery



Port Scanning



Service Identification



Banner/Version Enumeration



Configuration Analysis



Risk Assessment



Security Hardening



Continuous Monitoring

For your practical record, the strongest approach is to include screenshots of each command and its actual output, especially for the Nmap, Nikto, Netcat, Telnet, and Netdiscover scans. This makes the report demonstrate that the experiments were actually performed rather than relying on generic results.